

饿了么

美好生活 共享安全

饿了么第一届信息安全峰会

软件逆向分析在电子数据司法鉴定中的应用

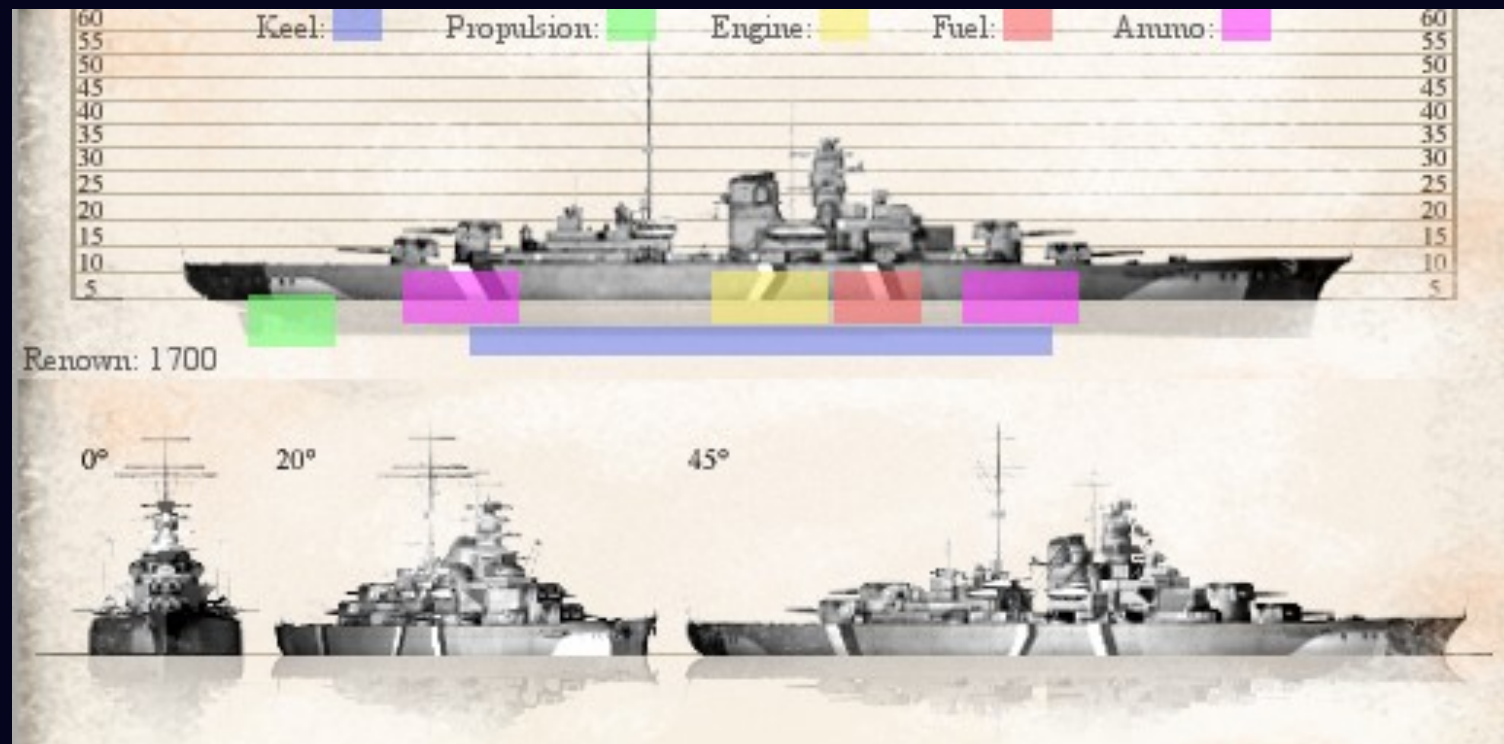
钱 林 松



懂了么安全应急响应中心
Elame Security Response Center

美好生活 共享安全

什么是逆向工程 & 起源



软件逆向分析

- 灰盒测试
- 动态调试
- 静态分析
 - 反编译
 - 反汇编

```
.text:004010D4      lea     eax, [ebp+Msg]
.text:004010D7      push   eax                ; lpMsg
.text:004010D8      call   ds:__imp_GetMessageA@16 ;
.text:004010DE      cmp     esi, esp
.text:004010E0      call   __chkesp
.text:004010E5      test   eax, eax
.text:004010E7      jz      short loc_401130
.text:004010E9      mov     esi, esp
.text:004010EB      lea     ecx, [ebp+Msg]
.text:004010EE      push   ecx                ; lpMsg
.text:004010EF      mov     edx, [ebp+hAccTable]
.text:004010F2      push   edx                ; hAccTable
.text:004010F3      mov     eax, [ebp+Msg.hwnd]
.text:004010F6      push   eax                ; hWnd
.text:004010F7      call   ds:__imp_TranslateAccelerator@16
.text:004010FD      cmp     esi, esp
.text:004010FF      call   __chkesp
.text:00401104      test   eax, eax
.text:00401106      jnz     short loc_40112E
```

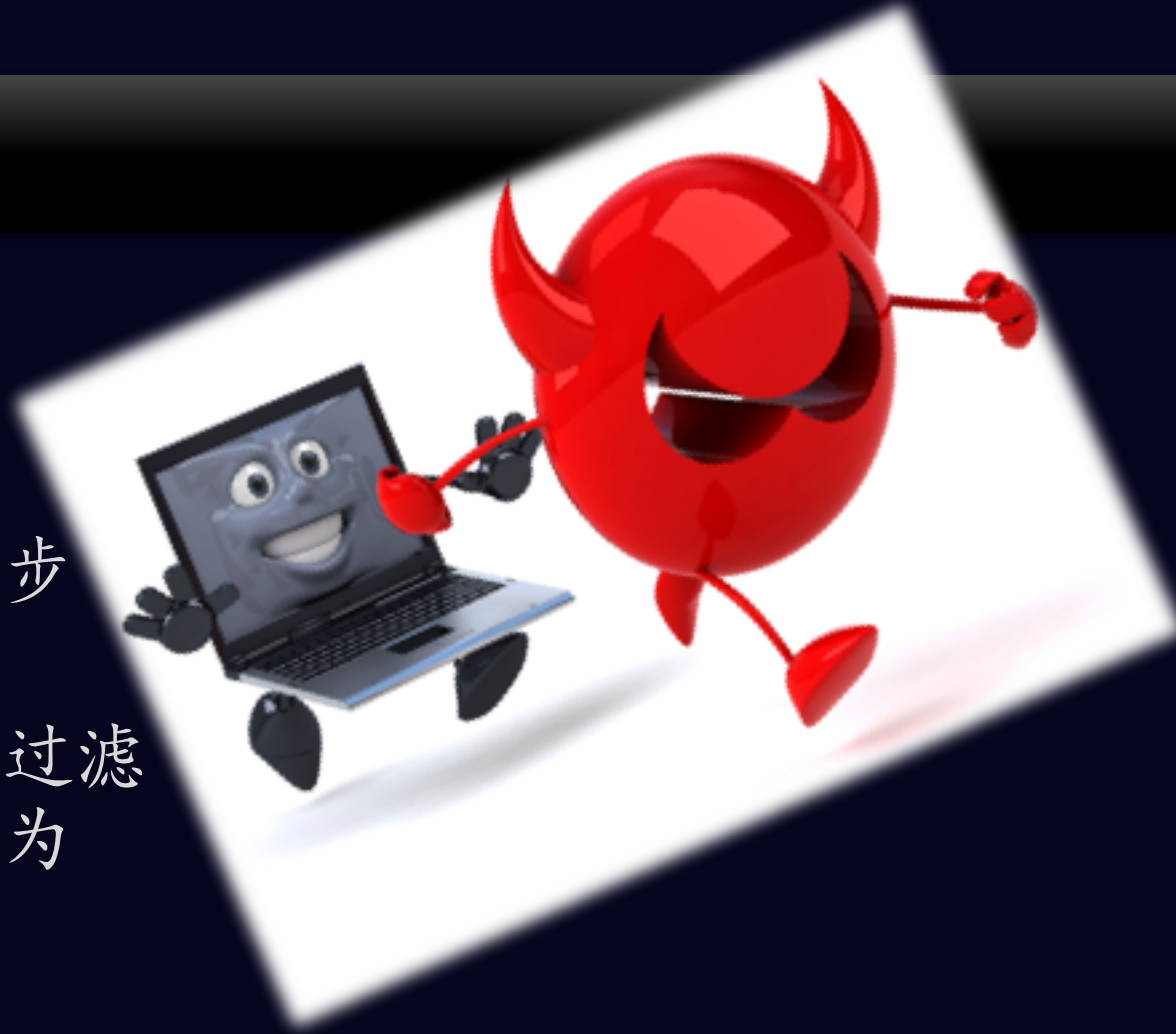
```
Data\Tencent\QQDownload\mediadl.cch
读文件  \Documents and Settings\All Users\Application
Data\Tencent\QQDownload\mediadl.cch
新建文件  \??\C:\WINDOWS\Registration\R000000000
读文件  \Documents and Settings\All Users\Application
Data\Tencent\QQDownload\mediadl.cch
读文件  \WINDOWS\Registration\R000000000007.clb
新建文件  \??\C:\Documents and Settings\All User
Data\Tencent\QQPCMgr\QMConfig.dat
新建文件  \??\C:\Documents and Settings\All User
Data\Tencent\QQPCMgr\QMConfig.dat
读文件  \Documents and Settings\All Users\Application
Data\Tencent\QQDownload\mediadl.cch
读文件  \Documents and Settings\All Users\Application
Data\Tencent\QQDownload\mediadl.cch
新建文件  \??\C:\Documents and Settings\All User
Data\Tencent\QQPCMgr\QMConfig.dat
```

```
MyRegisterClass(hInstance);
if ( InitInstance(hInstance, nShowCmd) )
{
    LoadAcceleratorsA(hInstance, (LPCSTR)0x6D);
    hAccTable = (HACCEL)_chkesp();
    while ( 1 )
    {
        GetMessageA(&Msg, 0, 0, 0);
        if ( !_chkesp() )
            break;
        TranslateAcceleratorA(Msg.hwnd, hAccTable, &Msg);
        if ( !_chkesp() )
        {
            TranslateMessage(&Msg);
            _chkesp();
            DispatchMessageA(&Msg);
            _chkesp();
        }
    }
}
```



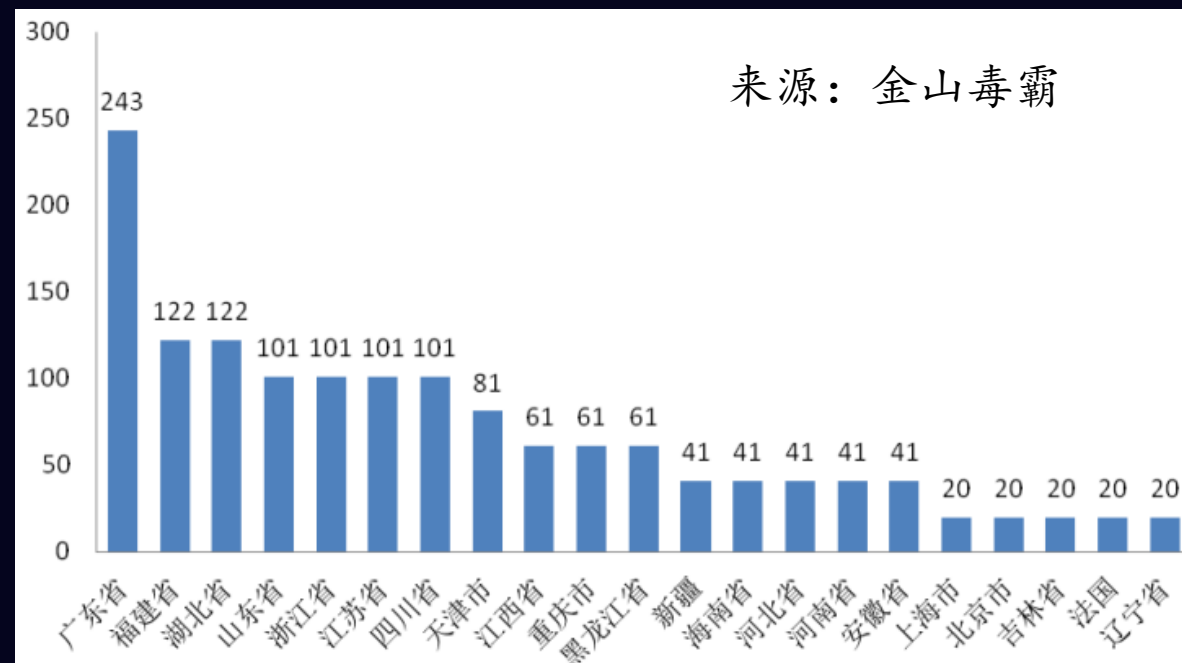
让我们从案例开始

- 背景介绍：“淘宝客”
- 逆向分析的目的：通过分析样本行为和技术细节，进而挖掘作者信息，为进一步分析提供条件
- 说明：略过加载驱动，文件过滤、网络过滤技术的介绍，直接介绍该样本的关键行为



淘 宝 客

- 将用户拦截、导向到指定页面
- 日感染量：1460



样本的行为分析

- 解密注册表信息及配置文件
- 样本将拦截的http特征字符串
- 样本对http流进行的替换
- 样本最终对用户的影响

行为分析—特征字符串

- 该样本内部保存了一组杀毒软件网站常用的HTTP特征字符串数组

```
.data:B223A82C off_B223A82C dd offset aPostFile_healt  
.data:B223A82C ; DATA XREF: subCheckIsSafeSoftNet+9↑o  
.data:B223A82C ; subCheckSafeSoftAddAllocCloseSpace+9↑o  
.data:B223A82C ; "POST /file_health_info.php HTTP/1.1*"  
.data:B223A830 dd offset aPostUpload_php ; "POST /upload.php HTTP/1.1*Host: *.360.c"...  
.data:B223A834 dd offset aPostQuery2Http ; "POST /query2 HTTP/1.1*Host: *.duba.net*"...  
.data:B223A838 dd offset aPostDuHttp1_1H ; "POST /du/ HTTP/1.1*Host: *.duba.net*"  
.data:B223A83C dd offset aGetFile_health ; "GET /file_health_info.php HTTP/1.1*Host"...  
.data:B223A840 dd offset aPostGetconf_ph ; "POST /getconf.php HTTP/1.1*Host: *.360."...  
.data:B223A844 dd offset aPostCloudquery ; "POST /cloudquery.php HTTP/1.1*"  
.data:B223A848 aHttp1_12000kCo db 'HTTP/1.1 200 OK',0Dh,0Ah
```



行为分析 — http拦截

- 当样本拦截到http请求以后,会遍历此特征字符串数组,并检查http请求是否符合杀毒软件请求的特征
- 如果是,就用一个关闭http的请求进行替换

```
text:000153F2 MDL_Len = dword ptr 0Ch
text:000153F2 arg_lpCloseNetSpaceAddr= dword ptr 10h
text:000153F2 arg_lpCloseNetSpaceSize= dword ptr 14h
text:000153F2
text:000153F2 mov edi, edi
text:000153F4 push ebp
text:000153F5 mov ebp, esp
text:000153F7 push ecx
text:000153F8 push ebx
text:000153F9 push esi
text:000153FA push edi
text:000153FB mov [ebp+var_NetFormatOffset], offset off_1D82C ; DATA XREF: subCheckIsSa
; subCheckSafeSoftAddAllocCloseSpace+91o
; "POST /file_health_info.php HTTP/1.1*"
; "POST /upload.php HTTP/1.1*Host: *.360.c"...
; "POST /query2 HTTP/1.1*Host: *.duba.net*"...
; "POST /du/ HTTP/1.1*Host: *.duba.net*"
; "GET /file_health_info.php HTTP/1.1*Host"...
; "POST /getconf.php HTTP/1.1*Host: *.360.c"...
; "POST /cloudquery.php HTTP/1.1*"
text:00015402 mov ebx, offset aHttp1_12000kCo ; "HTTP/1.1 200 OK\r\nConnection: close\r\n\r\n"
text:00015407 loc_15407: ; CODE XREF: subCheckSafeSoftAddAllocCloseSpace+58lj
text:00015407 mov eax, [ebp+var_NetFormatOffset]
text:0001540A mov eax, [eax]
text:0001540C test eax, eax
text:0001540E jz short NOT_A_SAFE_SOFT
text:00015410 push eax
text:00015411 [ebp+MDL_Len]
text:00015414 [ebp+MDL_Addr]
text:00015417 call subCheckNetString ;
; 函数作用: 检查协议格式是否符合某特征
;
text:00015417
text:00015417
text:0001541C test al, al
text:0001541E jz short NOT_A_SAFE_SOFT ; 不符合特征则跳转
;
; -----
; // 符合特征
; // 关闭的格式
text:00015420 mov eax, ebx
text:00015422 lea edx, [eax+1]
```

mov ebx, offset aHttp1_12000kCo ; "HTTP/1.1 200 OK\r\nConnection: close\r\n\r\n" 这个是传出的关闭连接的字符串

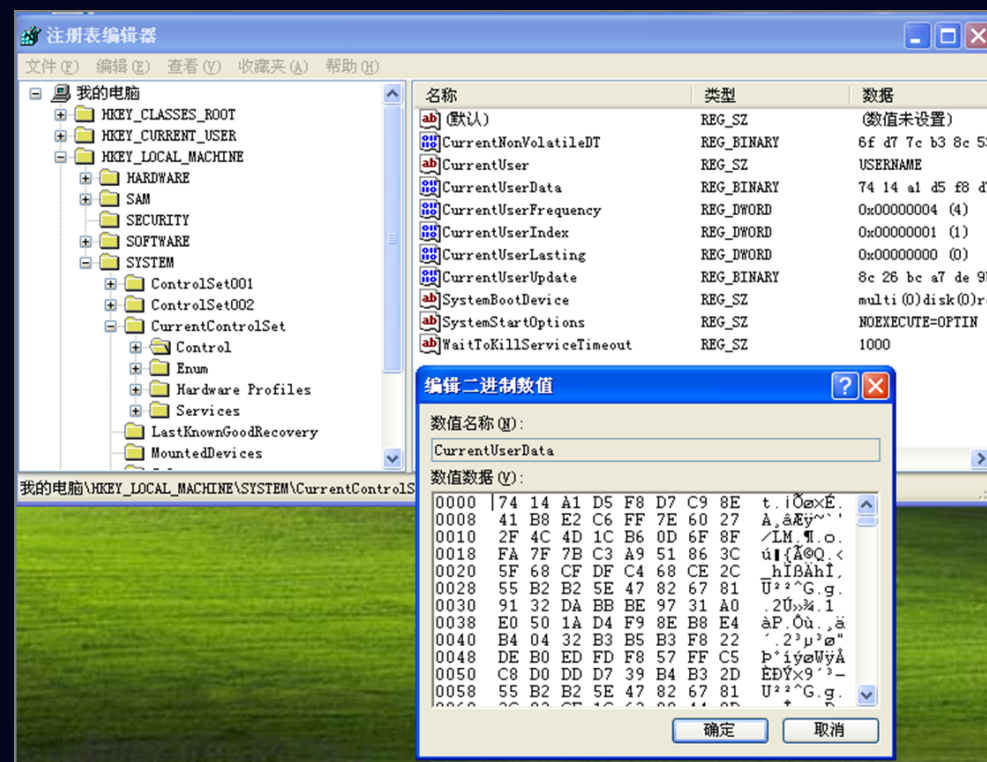
行为结论

- 此样本对杀毒软件网址进行拦截，并修改http请求，以达到阻止杀毒软件正常访问服务器或上传样本的目的。



行为分析—发现加密的配置文件

- 该样本在注册表
\\REGISTRY\\MACHINE\\SYSTEM\\CurrentControlSet\\Control的
CurrentUserData键内保存了购物
网站的配置信息，这个配置信息是
经过加密处理的。



行为分析—要拦截的网址特征字符串

```
1 GET /sug* HTTP/1.*Host: suggest.taobao.com
2 GET /jsclick* HTTP/1.*Host: www.atpanel.com
3 http://$[Host]$[Url]<html><body><a href="http://$[Host]$[Url]"></a></body></html>
4 GET /browse/search*q=* HTTP/1.*Host: search?.taobao.com
5 POST /browse/search* HTTP/1.*Host: search?.taobao.com
6 GET /search*q=* HTTP/1.*Host: search.taobao.com*
7 POST /search* HTTP/1.*Host: search.taobao.com**q=*
8 GET /search*q=* HTTP/1.*Host: s.taobao.com**
9 GET /search*q=* HTTP/1.*Host: s8.taobao.com**
```



行为分析—替换http请求

原内容

```
G E T / s e a r c h ? q = 1 & c o m m e n d = a l l & s
87cc441d s i d = s 5 - e & s a r c h _ t y p e = i t e m & s o u
87cc443a r c e I d = t b . i n d e x & s p m = 1 . 6 6 5 9 4 2 1 .
87cc4457 7 5 4 8 9 6 2 3 7 . 1 & i n i t i a t i v e _ i d = t b i
87cc4474 n d e x z _ 2 0 1 3 1 1 0 5 H T T P / 1 . 1 . A c c e
87cc4491 p t : i m a g e / g i f , i m a g e / j p e g , i m
87cc44ae a g e / p j p e g , i m a g e / p j p e g , * / * . .
87cc44cb R e f e r e r : h t t p : / / w w w . t a o b a o . c o
87cc44e8 m / . . A c c e p t - L a n g u a g e : z h - c n . . U
87cc4505 s e r - A g e n t : M o z i l l a / 4 . 0 ( c o m p a
87cc4522 t i b l e ; M S I E 8 . 0 ; W i n d o w s N T 5
87cc453f . 1 ; T r i d e n t / 4 . 0 ) . . A c c e p t - E n c o
87cc455c d i n g : g z i p , d e f l a t e . . H o s t : s .
87cc4579 t a o b a o . c o m . . C o n n e c t i o n : K e e p -
87cc4596 A l i v e . . C o o k i e : c n a = Z N n + C t K R U U
87cc45b3 A C A X O v 0 L q T 0 s 5 g ; c o o k i e 2 = 0 0 2 8 9
87cc45d0 3 2 4 7 d 6 4 b 7 a 8 9 3 1 a c a 4 6 7 6 e 5 1 c 5 c ;
87cc45ed t = e c 9 e 3 8 8 b 5 c c 0 0 5 9 e 6 6 f 2 a 5 4 5 1 0 7
87cc460a 9 8 c c e ; u c 1 = c o o k i e 1 4 = U o L U 6 N u d d
87cc4627 F % 2 F l c Q % 3 D % 3 D ; v = 0 ; m t = c i % 3 D 0
87cc4644 _ 0 . . . . N O h L G v q X S M U T 1 o A k G H H k 3 2 H
87cc4661 N % 2 B P H m u W 9 c y W d Q f T 2 X W s j T A m X P X A
87cc467e D 6 E N E T 9 c D 0 C K u E l % 2 F & u = h t t p % 3 A %
87cc469b 2 F % 2 F r o m o n . t m a l l . c o m & k = 1 9 3 " , "
87cc46b8 d a t a " : " h t t p : \ / \ / i . m m c d n . c n \ / s
87cc46d5 i m b a \ / i m g \ / T 1 0 F . r f g N b X X b 1 u p j X
87cc46f2 . j p g " , " b a n n e r m a k e r " : " " } )
```

替换后的内容

```
87ccb008
87ccb008 H T T P / 1 . 1 3 0 2 F o u n d . . L o c a t i o n :
87ccb025 h t t p : / / s 8 . t a o b a o . c o m / s e a r c h ?
87ccb042 q = 1 & c a t = 0 & p i d = m m _ 3 0 6 8 5 9 7 4 _ 3 3 2
87ccb05f 3 0 1 6 _ 1 0 7 9 9 5 3 2 & m o d e = 2 3 & c o m m e n d
87ccb07c = 1 % 2 C 2 . . . < h t m l > < b o d y > < a h r e f
87ccb099 = " h t t p : / / s 8 . t a o b a o . c o m / s e a r c h
87ccb0b6 ? q = k e y w o r d & c a t = 0 & p i d = m m _ 3 0 6 8 5
87ccb0d3 9 7 4 _ 3 3 2 3 0 1 6 _ 1 0 7 9 9 5 3 2 & m o d e = 2 3 &
87ccb0f0 c o m m e n d = 1 % 2 C 2 " > < / a > < / b o d y > < / h
87ccb10d t m l >
```

替换请求并向下发送

```
.text:B2230253 call ds:IoAllocateMdl ; //分配足够映射一块缓存的MDL,
.text:B2230259 mov ebx, eax
.text:B223025B cmp ebx, edi
.text:B223025D jnz short loc_B2230269
.text:B223025F push [ebp+lpOutSpaceAddr] ; P
.text:B2230262 call subReleaseSpace
.text:B2230267 jmp short DOT_HANDLE_DIRECT_CALL_DRIVER
; -----
.text:B2230269 ; CODE XREF: subDeal_TDI_SEND+245↑j
.text:B2230269 loc_B2230269: ; MemoryDescriptorList
.text:B2230269 push ebx
.text:B223026A call ds:MmBuildMdlForNonPagedPool ; //把刚才分配缓存的映射关系保存到MDL中
.text:B2230270 mov eax, [esi+4]
.text:B2230273 mov [ebp+Irp], eax
.text:B2230276 mov eax, [ebp+var_SendLen]
.text:B2230279 mov edi, [eax]
.text:B223027B mov [esi+4], ebx ; //把旧的MDL换成新MDL的地址
.text:B223027E mov eax, [ebp+&lpOutLength]
.text:B2230281 mov ecx, [ebp+var_SendLen]
.text:B2230284 mov [ecx], eax
.text:B2230286 push esi ; Irp
.text:B2230287 mov eax, [ebp+var_DeviceExtension]
.text:B223028A push dword ptr [eax+0Ch] ; DeviceObject
.text:B223028D call subSendIrpToLowerDriver ; //把IRP发送下到下一个设备
.text:B2230292 mov eax, [ebp+Irp]
.text:B2230295 mov [esi+4], eax
.text:B2230298 mov eax, [ebp+var_SendLen]
.text:B223029B mov [eax], edi
.text:B223029D mov [esi+1Ch], edi
.text:B22302A0 push ebx ; Mdl
.text:B22302A1 call ds:IoFreeMdl
.text:B22302A7 push [ebp+lpOutSpaceAddr] ; P
.text:B22302AA call subReleaseSpace
.text:B22302AF mov edi, [esi+18h]
.text:B22302B2 jmp loc_B22301B8
```



从样本中提取到的淘宝PID

mm_30685818_3322984_10799476

mm_30683801_3323295_10799945

mm_30685856_3322988_10799488

mm_30685904_3322997_10799506

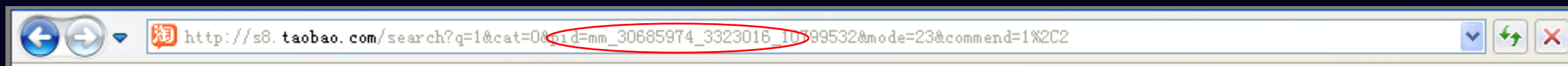
mm_30685939_3323013_10799525

... ..



行为结果—浏览器url被篡改

- 所圈内容就是被篡改的淘宝PID



行为结论—恶意软件

- 该样本在未得到授权的情况下，影响安全软件的正常工作，拦截并篡改用户的http请求，尤其是目标为购物网站类的请求。其行为影响操作系统以及数据的完整性、可控性和保密性，已经满足恶意程序的鉴定条件。



样本特征及开发团队跟踪

- 驱动特征分析
- 配置文件名及路径特征分析
- 服务器地址/IP特征分析



驱动名称和符号链接

```
mov     word ptr [ebp+var_Equ7A41], ax
pop     eax
mov     word ptr [ebp+var_Equ7A41+2], ax
mov     esi, offset aDeviceHrdrv ; "\\Device\\HrDrv"
push    esi                ; SourceString
lea     eax, [ebp+DestinationString]
xor     ebx, ebx
push    eax                ; DestinationString
mov     [ebp+Object], ebx
mov     [ebp+DeviceObject], ebx
call    edi ; RtlInitUnicodeString ; 初始化字符串 "\\Device\\HrDrv"
xor     eax, eax
cmp     ax, word ptr aDeviceHrdrv ; "\\Device\\HrDrv"
jz      short loc_11849
```

```
.text:00012852      push    offset aDosdevicesHrdr ; "\\DosDevices\\HrDrv"
.text:00012857      lea     eax, [ebp+SymbolicLinkName]
.text:0001285A      push    eax                ; DestinationString
.text:0001285B      call    esi ; RtlInitUnicodeString
.text:0001285D      lea     eax, [ebp+DeviceName]
.text:00012860      push    eax                ; DeviceName
.text:00012861      lea     eax, [ebp+SymbolicLinkName]
.text:00012864      push    eax                ; SymbolicLinkName
.text:00012865      call    ds:IoCreateSymbolicLink ; 创建HrDr设备的符号链接 "\\DosDevices\\HrDrv"
```



驱动符号和符号链接

```
.text:00011933      push     edi
.text:00011934      mov     edi, ds:RtlInitUnicodeString
.text:0001193A      push    offset aDeviceNetsafe0 ; "\\Device\\NetSafe0"
.text:0001193F      lea     eax, [ebp+szDriverStartKey]
.text:00011942      xor     ebx, ebx
```

```
.text:00011B05      push    offset aDosdevicesNets ; "\\DosDevices\\NetSafe0"
.text:00011B0A      lea     eax, [ebp+SymbolicLinkName]
.text:00011B0D      push    eax ; DestinationString
.text:00011B0E      call    edi ; RtlInitUnicodeString
.text:00011B10      lea     eax, [ebp+szDriverStartKey]
.text:00011B13      push    eax ; DeviceName
.text:00011B14      lea     eax, [ebp+SymbolicLinkName]
.text:00011B17      push    eax ; SymbolicLinkName
.text:00011B18      call    ds:IoCreateSymbolicLink ; //创建这个设备的符号链接 L"\\DosDevices\\NetSafe0"
```



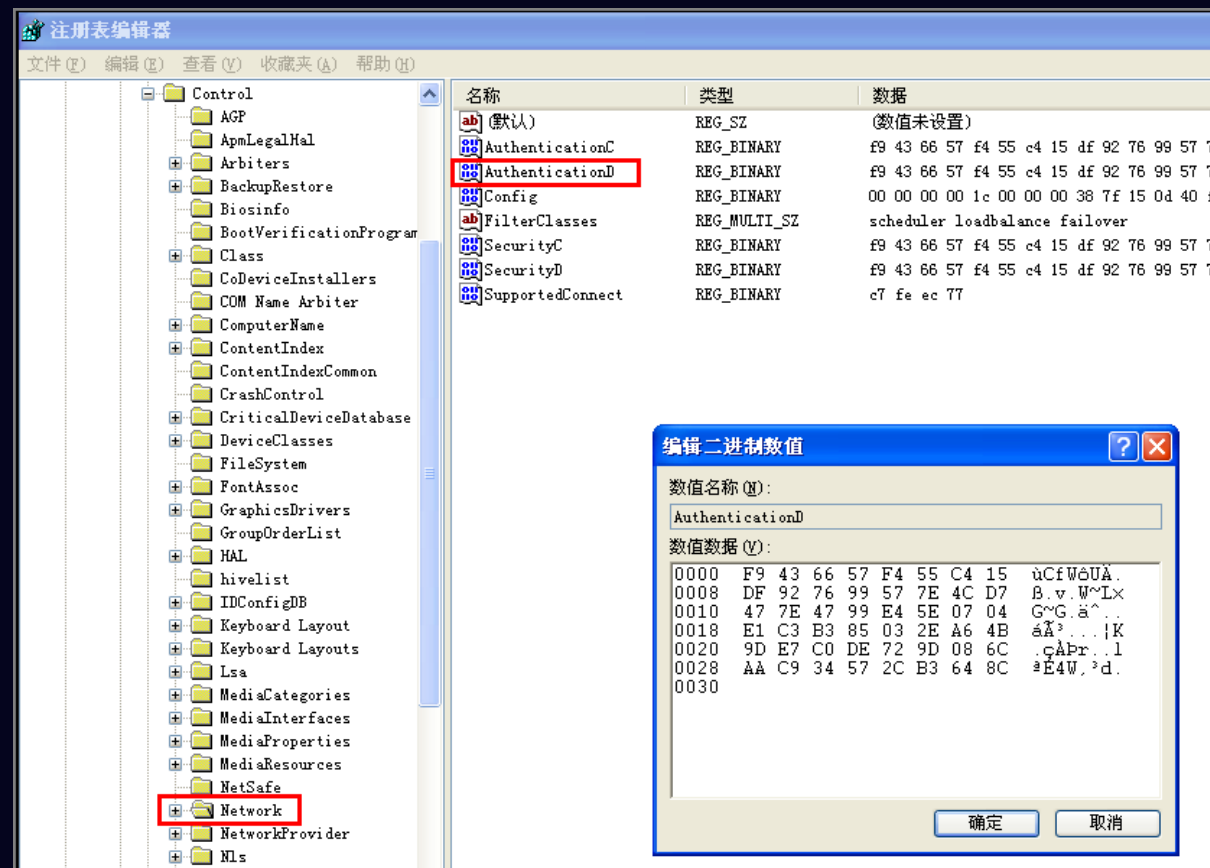
配置文件名和路径

```
.text:B222F8F5      mov     esi, offset aWuyouWyupfile3 ; "/wuyou/wyupfile/36/36.ini"  
.text:B222F8FA      push    g_wuYou_ini  
.text:B222F900      mov     edi, offset g_iniFilePath
```



升级的URL及IP地址

- 有一个线程每隔6小时查询注册表\REGISTRY\MACHINE\SYSTEM\CurrentControlSet\Control\Network的AuthenticationD"值. 并进行解密



URL及IP定位

```
.text:B183DF58      add     esp, 24h
.text:B183DF5B      push    offset s__RegistryMachineSystemCurrentcontrolsetControlNetwork ; "\\REGISTRY\\MACHINE\\SYSTEM\\CurrentControl"
.text:B183DF60      lea     eax, [esp+334h+DestinationString]
.text:B183DF64      push    eax ; DestinationString
.text:B183DF65      mov     [esp+338h+var_328], ebx
.text:B183DF69      call    esi ; RtlInitUnicodeString
.text:B183DF6B      push    offset s__AuthenticationD ; "AuthenticationD"
.text:B183DF70      lea     ecx, [esp+334h+ValueName]
.text:B183DF74      push    ecx ; DestinationString
.text:B183DF75      call    esi ; RtlInitUnicodeString
.text:B183DF77      push    offset s__SecurityD ; "SecurityD"
.text:B183DF7C      lea     edx, [esp+334h+var_31C]
.text:B183DF80      push    edx ; DestinationString
.text:B183DF81      call    esi ; RtlInitUnicodeString
.text:B183DF83      lea     eax, [esp+330h+var_328]
.text:B183DF87      push    eax ; int
.text:B183DF88      lea     ecx, [esp+334h+var_30C]
.text:B183DF8C      push    ecx ; void *
.text:B183DF8D      push    ebx ; int
.text:B183DF8E      lea     edx, [esp+33Ch+ValueName]
.text:B183DF92      push    edx ; ValueName
.text:B183DF93      lea     eax, [esp+340h+DestinationString]
.text:B183DF97      push    eax ; Handle
.text:B183DF98      mov     [esp+344h+var_328], 104h
.text:B183DFA0      call    QueryValueAtRegkey ; //查询注册表\REGISTRY\MACHINE\SYSTEM\CurrentControlSet\Control\Network\AuthenticationD值。
.text:B183DFA5      test    eax, eax
.text:B183DFA7      jl      loc_B183E0BB
.text:B183DFA7
.text:B183DFA0      mov     ecx, [esp+330h+var_328]
.text:B183DFB1      push    ecx ; size_t
.text:B183DFB2      lea     edx, [esp+334h+var_30C]
.text:B183DFB6      push    edx ; int
.text:B183DFB7      mov     eax, edx
.text:B183DFB9      push    eax ; int
.text:B183DFBA      push    offset s__Nsurlkey ; "Nsurlkey"
.text:B183DFBF      call    decodeUpdateUrl ; //调用解密函数对注册表进行解密
.text:B183DFBF
.text:B183DFC4      lea     ecx, [esp+330h+var_328] ; //解密后的字符串为http://xml. .net:83/union/uploads/27/27.ini
```

升级的URL或IP地址

- 经解密得样本的更新地址:
- xml.****.net:83/union/upload/27/27.ini

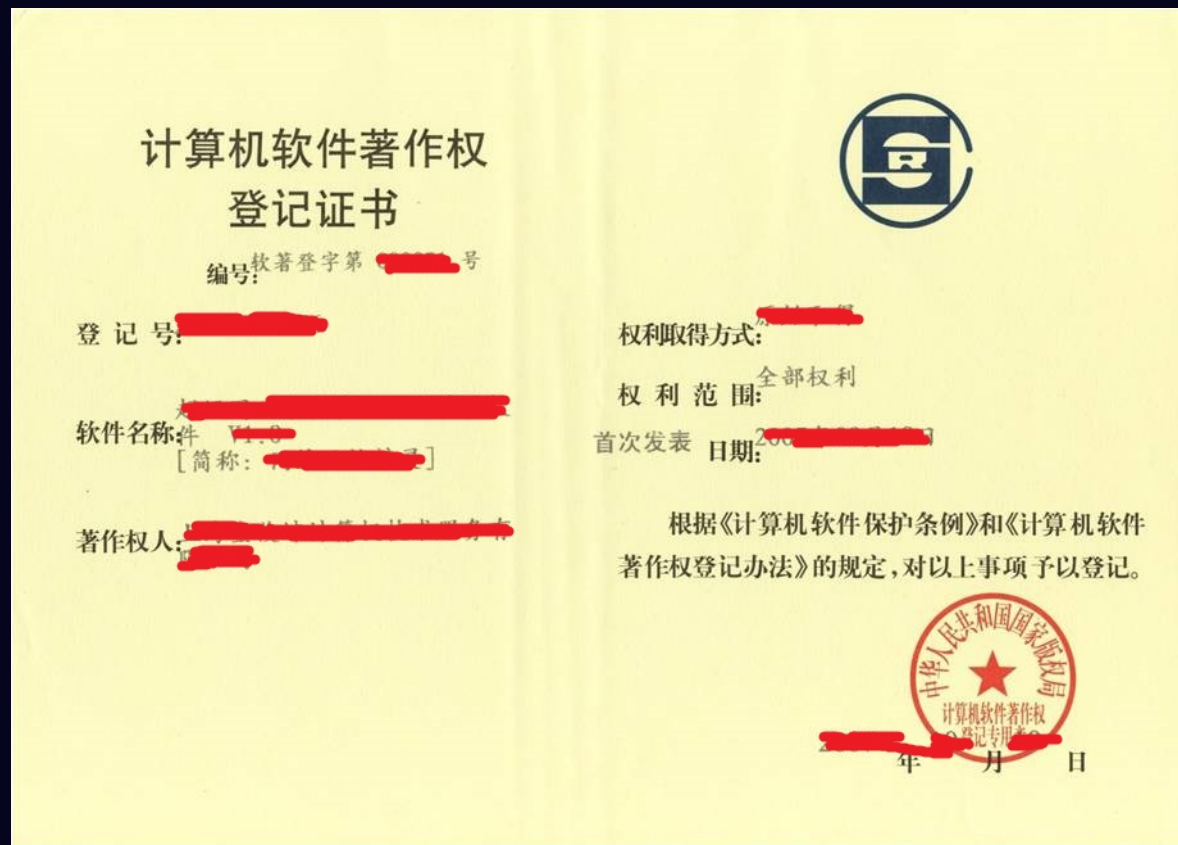
```
mov     eax, edx
push    eax                ; int
push    offset s__Nsurlkey ; "NsUrlKey"
call    decodeUpdateUrl ; http://xml.***.net:83/union/uploads/27/27.ini

lea     ecx, [esp+330h+var_328]
push    ecx                ; int
lea     edx, [esp+334h+var_208]
push    edx                : void *
```



通过whois及搜索引擎挖掘域名信息

- 该团队拥有正在销售的商业产品，而且是自主开发的。
- 根据其产品描述，是一款基于windows系统驱动开发的磁盘过滤技术的****软件，而该样本应用了驱动技术。而且同样有磁盘驱动。两个程序的关键技术接近，说明该公司具备开发此样本的技术条件。



锁定目标

开发团队跟踪

上海 [redacted] 机技术服务有限公司
当前打 [redacted] !

企业基本信息		企业法人营业执照	
名称:	[redacted]	注册号:	[redacted]
法定代表人姓名:	[redacted]	住所:	上海市 [redacted]
注册资本:	[redacted] 万人民币	实收资本:	[redacted]
企业状态:	确立	公司类型:	[redacted]
成立日期:	[redacted]	营业期限:	[redacted]
登记机关:	[redacted]	受理机关:	[redacted]
经营范围:	计算机技术服务、技术开发, 计算机网络工程, 计算机软硬件及耗材, 通讯设备, 电子产品, 文化办公用品, 机械设备, 五金交电, 仪器仪表销售 (涉及行政许可的凭许可证经营)。		

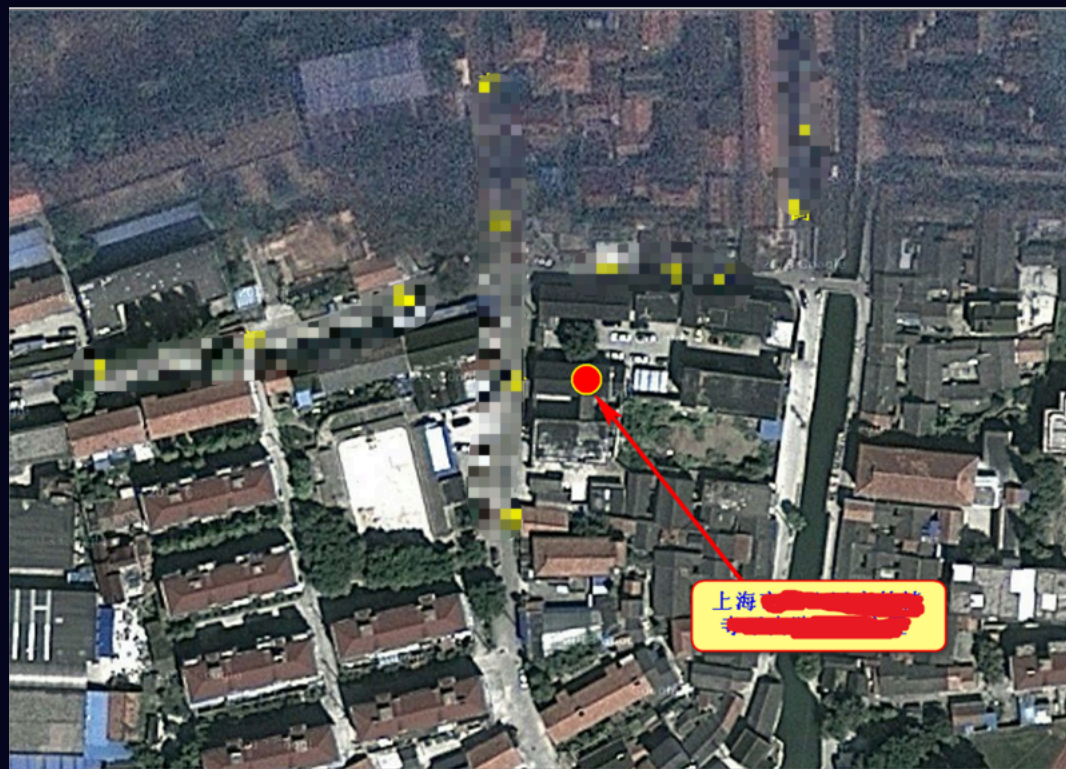
网站基本信息	
亮照标识编号:	[redacted]
域名:	[redacted]
ISP提供商:	[redacted]
服务器所在地:	[redacted]
网站名称:	上海 [redacted]
IP地址:	[redacted]
网站类型:	[redacted]

监督投诉 | 联系我们 | 分局热线链接 | 相关网站链接

版权所有: 上 [redacted]
地址: 上 [redacted]
技术支持: [redacted]
建议使用: [redacted]



锁定目标



分析结束了？



饿了么安全应急响应中心
Elame Security Response Center

美好生活 共享安全

To be continued...



懂了么安全应急响应中心
Elame Security Response Center

美好生活 共享安全

同源性分析

- 驱动符号同源分析
- 注册表结构同源分析
- 解密函数同源分析
- URL服务器同源分析



驱动符号同源分析

- 另一个样本，时间关系，略去行为分析
- 两样本驱动和符号名称一致

```
.text:00015D09      mov     edi, ds:RtlInitUnicodeString
.text:00015D0F      push   offset aDeviceNetsafe0 ; "\\Device\\NetSafe0"
.text:00015D14      lea     eax, [esp+224h+DestinationString]
.text:00015D18      push   eax                     ; DestinationString
.text:00015D19      mov     [esp+228h+StartContext], 0
```

```
.text:00015D4D      mov     ecx, [ecx+20h]
.text:00015D50      push   offset aDosdevicesNets ; "\\DosDevices\\NetSafe0"
.text:00015D55      lea     edx, [esp+224h+SymbolicLinkName]
.text:00015D59      push   edx                     ; DestinationString
```

注册表同源分析

2个样本自动升级的配置信息都加密存放在注册表，而且结构一致

样本1：

- `\REGISTRY\MACHINE\SYSTEM\CurrentControlSet\Control\Network`下的AuthenTicationD子键和SecurityD子键

样本2：

- `\REGISTRY\MACHINE\SYSTEM\CurrentControlSet\Control\Network`下的AuthenTicationD子键和SecurityD子键



解密函数同源分析

- 2个样本在解密更新地址前, 都压入了同一字符串, 作为key
- 样本1
样本2

.text:B1B3E001	push	offset s__Nsurlkey ; "NsUrlKey"
.text:B1B3E006	call	decodeUpdateUrl

.text:B16711D9	push	eax ; int
.text:B16711DA	push	offset aNsurlkey ; "NsUrlKey"
.text:B16711DF	call	subDecodeUpdateUrl



升级服务器URL同源分析

样本 1 的更新地址为

[http://xml\[REDACTED\].net:83/union/uploads/27/27.ini](http://xml[REDACTED].net:83/union/uploads/27/27.ini)

[http://xml\[REDACTED\].net:83/union/uploads/27/27.conf](http://xml[REDACTED].net:83/union/uploads/27/27.conf)

```
b142666c h t t p : / / x m l . [REDACTED] . n e t : 8 3 / u n i o n / u p  
b142668d l o a d s / 2 7 / 2 7 . i n i . . . . .  
b14266ae . . . . .
```

样本 2 的更新地址为

[http://xml\[REDACTED\].net:83/union/uploads/34/34.ini](http://xml[REDACTED].net:83/union/uploads/34/34.ini)

[http://xml\[REDACTED\].net:83/union/uploads/34/34.conf](http://xml[REDACTED].net:83/union/uploads/34/34.conf)

```
b15ab66c h t t p : / / x m l . [REDACTED] . n e t : 8 3 / u n i o n / u p  
b15ab68e o a d s / 3 4 / 3 4 . i n i . . . . .  
b15ab6b0 . . . . .
```



同源性对比

特征	样本1	样本2
创建设备名称和符号链接	✓	✓ 相同
拦截杀软的匹配字符串表	✓	✓ 几乎相同且顺序一致
更新服务器地址	服务器地址相同	
解密特征字符串	“NsUrKey”	“NsUrKey” 相同
注册表信息	✓	✓ 几乎相同



结论



饿了么安全应急响应中心
Elame Security Response Center

美好生活 共享安全

同源分析常用的参考依据

- 受益者信息一致或者具备某种关联
- 逆向分析后，得到的源码极其一致，甚至连源码里的错误都一致
- 逆向分析后，得到的注册表名称、内核对象命名、有关的URL、SQL语句、提示信息等一致
- 某些编译选项造成的信息泄露，如断言、调试信息、工程结构信息等

有图有真相—常见的软件信息泄露途径

- SQL信息泄露
- 调试信息泄露
- 工程结构泄露
- 内核对象名称泄露



SQL信息泄露

005A7042	push	.0064AD0C	DROP TABLE IF EXISTS %Q.'%q_co	.
005A7062	push	.0064ACE4	DROP TABLE IF EXISTS %Q.'%q_se	s'
005A707A	push	.0064ACC0	DROP TABLE IF EXISTS %Q.'%q_se	.
005A7092	push	.0064AC98	DROP TABLE IF EXISTS %Q.'%q_do	.
005A70AD	push	.0064AC74	DROP TABLE IF EXISTS %Q.'%q_st	.
005A70F5	push	.0064AED8	docid INTEGER PRIMARY KEY	
005A7116	push	.0064AECC	%z, 'c%d%q'	
005A7143	push	.0064AEA8	CREATE TABLE %Q.'%q_cont	
005A7165	push	.0064AE60	CREATE TABLE %Q.'%q_seg	RY KEY, block
005A717D	push	.0064ADC0	CREATE TABLE %Q.'%q_seg	ER,start_bloc
005A71A1	push	.0064AD78	CREATE TABLE %Q.'%q_docs	KEY, size BLO
005A71B9	push	.0064AD34	CREATE TABLE %Q.'%q_stat	value BLOB);
005A7257	push	.0064AFFC	ALTER TABLE %Q.'%q_cont	;
005A7293	push	.0064AFC4	ALTER TABLE %Q.'%q_docs	;
005A72AC	push	.0064AF94	ALTER TABLE %Q.'%q_stat	



调试信息泄露

```
"..." .data:1003... 0000003D C [%s]==>[%s] GyroAngle:%f AOB:%f Range:%f Distance:%f Tube:%s
"..." .data:1003... 00000018 C DeleteAttackerList [%s]
"..." .data:1003... 0000000E C TorpedoAttack?
"..." .data:1003... 00000006 C ERROR
"..." .data:1003... 00000017 C InsertAttackerList [%s]
"..." .data:1003... 0000004A C [Error]: ComputeTorpedoGyroAngle(): pAttacker->m_pSubTorpedoSys is NU...
"..." .data:1003... 0000003E C [Error]: ComputeTorpedoGyroAngle(): pAttackerObject is NULL.
"..." .data:1003... 00000038 C [Error]: ComputeTorpedoGyroAngle(): pEnemyObject is NULL.
```



工程结构信息泄露

```
0051698D push 00532898
00516AE3 push 005328A0
00516D3D push 0051EFFC
00517005 push 00532CDC
0051702B push 00532CD0
00517042 push 00532CC4
00517059 push 00532CB8
005170B5 push 00532CAC
005170CF push 00532C9C
00517146 push 00532D58
00517176 push 00532D50
0051717F push 00532D58
005171A2 push 00532D48
005171AB push 00532D58
005171CE push 00532D34
005171D7 push 00532D58
005171FA push 00532D20
00517203 push 00532D58
00517226 push 00532D14
0051722F push 00532D58
00517252 push 00532D04
0051725B push 00532D58
0051727E push 00532CF8
00517287 push 00532D58
005172AB push 00532CE8
005174DC push 00532D78

src
e:\[redacted]\[redacted]_root\src\[redacted]ds\inoutcmd\[redacted]ons.h
[redacted]d
[redacted]ler
[redacted]h
[redacted]h
[redacted]se
[redacted]derKeel
.\[redacted]\[redacted]ns.cpp
[redacted]ler
.\[redacted]\[redacted]ns.cpp
Ca[redacted]\[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
Or[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
Or[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
En[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
Or[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
Tr[redacted]ns.cpp
.\[redacted]\[redacted]ns.cpp
En[redacted]
Th[redacted] %s doesn't know this command. The source state was: %s
```

[s] .rdata:B167... 00000044 C d:\\Program Design\\CompanyProjects\\Out\\NetSafe\\Load\\bin\\fre\\Load.pdb

[s] .text:B2239... 00000020 C d:\\young\\httpprdr\\driver\\httpk.c



对象名称泄露

```
??_ROM28      dd offset ??_7type_info@@6B@ ; DAT
               ; .rdata:s
               ; const ty
               dd 0
a_pavcmymexcepti db '.PAVCMMyException@@',0
```



逆向分析在软件领域有什么作用？



逆向分析与不同领域结合，有不同作用

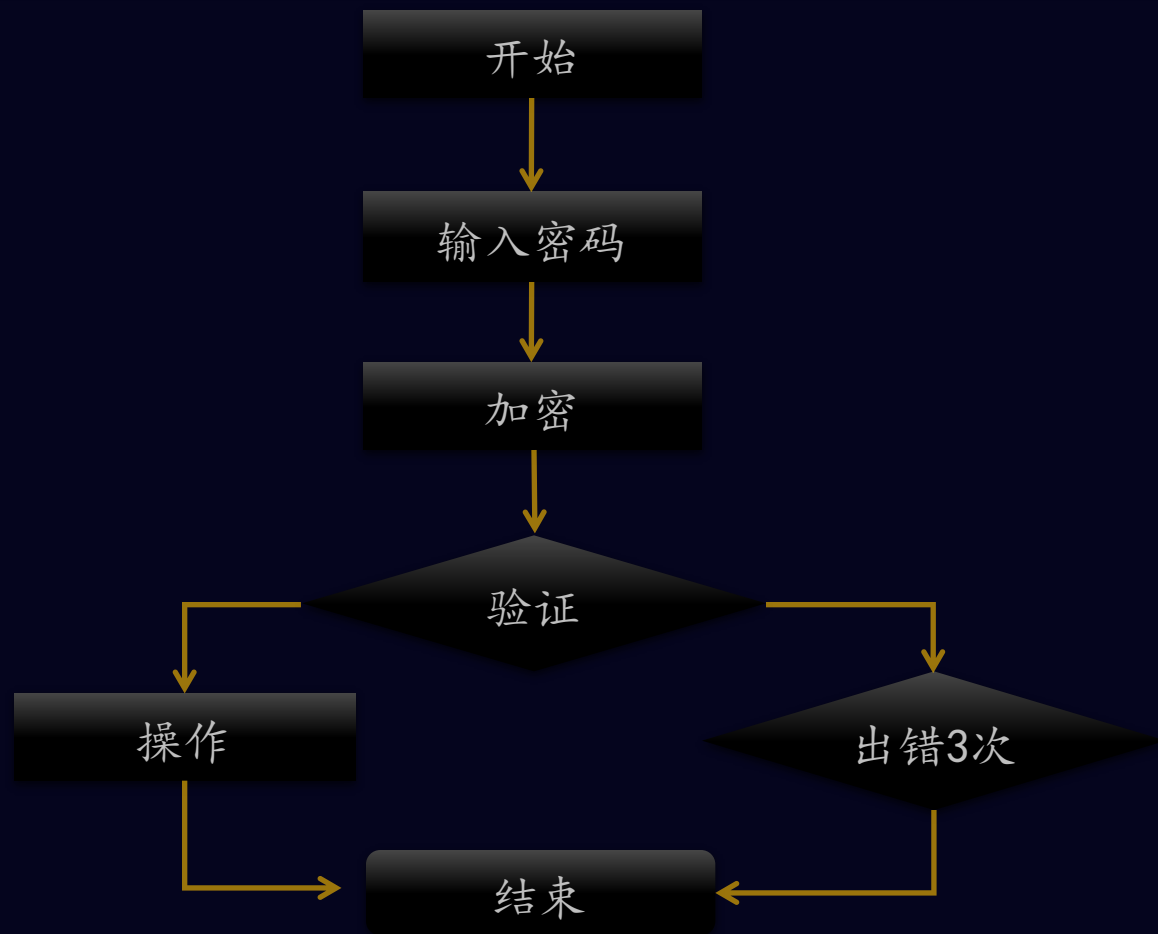
防守	攻击
信息加密	信息解密
加壳	脱壳
病毒防御	病毒隐蔽和传播
漏洞修复和防范	漏洞攻击
游戏安全	外挂
移动安全	信息窃取
电子数据取证	取证对抗



加密 VS 解密

- 逆向分析得到算法原理后, 算法求解或篡改代码获得授权
- 设计用户认证算法

加密 vs 解密



加壳 VS 脱壳

- 静态脱壳、内存Dump脱壳



- 对可执行文件内的代码和数据进行数学变换，目的是减少体积（压缩壳）或者提高逆向分析的难度（保护壳）

加壳 VS 脱壳

- 开发针对性的辅助工具，对混淆膨胀的代码作出优化，对虚拟化的代码进行还原
- 壳肉相连、关键代码混淆膨胀甚至虚拟化



技术炫耀型病毒

- 感染，隐匿，爆发

- 分析样本，了解机制按特征予以查杀



技术炫耀型病毒

- 扩大样本俘获渠道，主动防御，行为判定，白名单，虚拟执行
- 多态变型，人工免杀

盈利型病毒传播

- 反虚拟检测、对抗保护软件、社会工程、挟以用户的刚性需求
- 客户端收集样本，每个用户既是安全的受益者，也是维护安全的参与者



漏洞攻防

- 自动化Fuzz，产业化
- 监视或过滤畸形数据，定位和分析漏洞利用原因，安全服务型企业积极和软件厂商沟通
- 发现漏洞，写出exploit，渗透目标
- 产品被动升级，提高开发团队安全意识

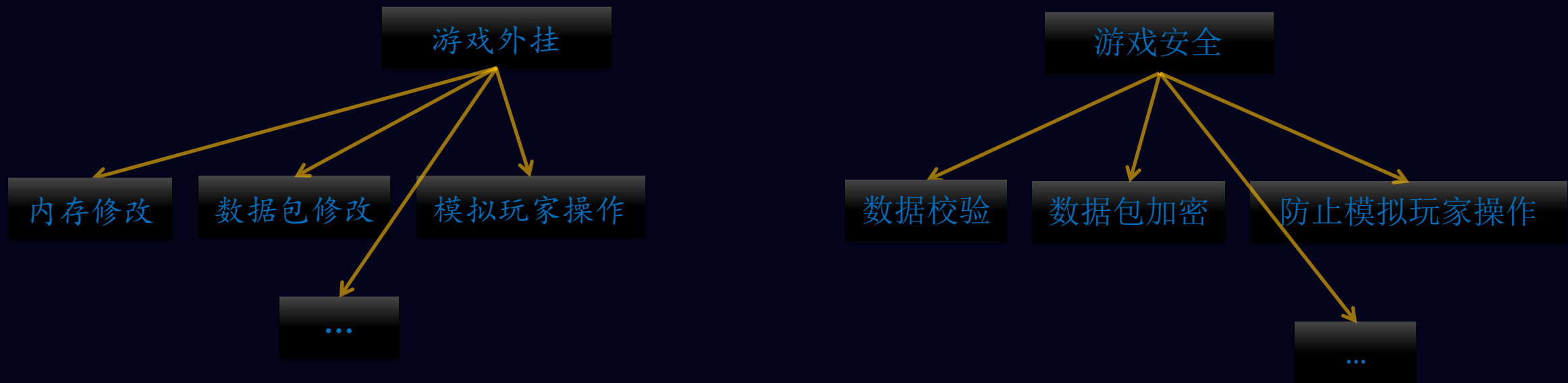


游戏攻防

- 技术更加细分：内存修改，数据包修改，模拟玩家操作等。
- 保护同时也具备综合性，数据校验，数据包加密，防止篡改，或者数据人工控制，防止程序模拟玩家等
- 游戏数据的篡改。以作弊为目的
- 针对游戏的关键数据进行保护，或者截获外挂样本后，分析其功能，对症下药



游戏攻防



游戏攻防

- 行业更加细分：破解，生产，盗号，私服…以盈利为目的
- 技术对抗的同时，运用法律武器



信息窃取 VS 移动安全

- 攻击的方将是会综合应用前所述的技，目能还会是非法盈手机。而战的场可上，比如车的载导航、外设备要，害部门禁系、统等
- 移动设备上流氓程序，目的费是信息换取利益，或者恶意消

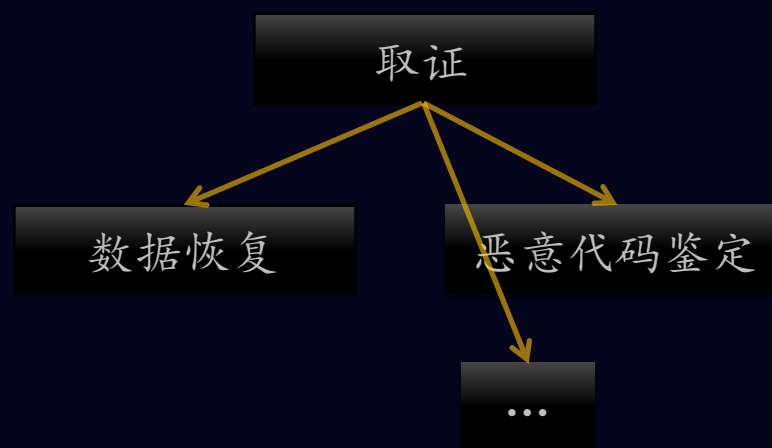
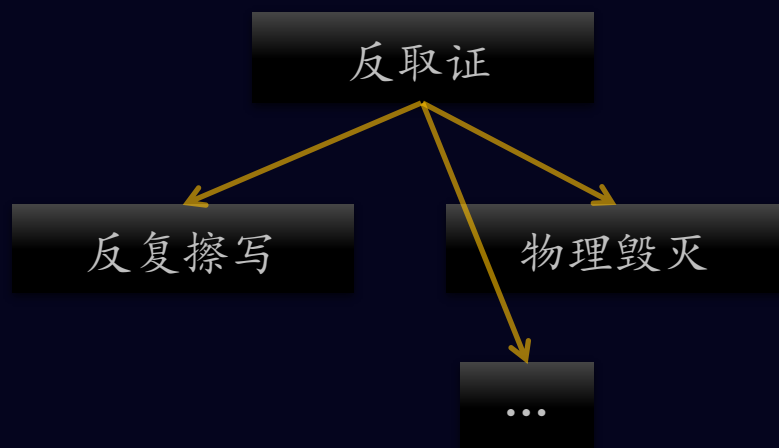
- 尚属起步阶段，但是各大安全厂商高度重视，最终解决问题还得多方通力配合



取证 VS 反取证

- 反复擦写，物理毁灭，法律边界比如开发者故意留下溢出的漏洞，伪造同源性

- 电子数据的恢复以及分析，恶意代码的鉴定，多样本同一性的鉴定



逆向知识结构

- 数学基础
- C/C++/数据结构
- 基本开发技能
- 汇编语言
- 操作系统接口
- 操作系统内核
- 编译原理



感谢

- 感谢 金山毒霸提供数据支持
- 感谢 武汉科锐、看雪论坛提供技术支持

Thank you!





饿了么安全应急响应中心
Eleme Security Response Center

THANKS

拉扎斯网络科技（上海）有限公司
Rajax Network & Tehnology Co

